

OpenVPN

- Ofrece seguridad comparable con IPsec
- Utiliza TLS/SSL para la autenticación de los endpoints y el intercambio de claves
- Logra un comportamiento similar a ESP para el canal de datos.

SSL

- Secure Sockets Layer
- Considerado el protocolo de túnel de capa de transporte más omnipresente
 - Conocido por permitir conexiones seguras en la Web (HTTPS)
 - Tiene muchas otras aplicaciones y puede utilizarse para construir túneles de capa de transporte de propósito general
- Especificación originada en 1994 por la empresa Netscape, interesada en una forma de asegurar ciertas transacciones realizadas con su navegador web del mismo nombre
- Versión 2 (SSL 2 liberada en el mismo año)

SSL

- SSL 2 tuvo algunos problemas de seguridad
- En 1995 Netscape libera la versión 3 (SSL 3) completamente reescrito
- En 1996 el IETF intenta estandarizar el protocolo y por razones políticas, fue nombrado Transport Layer Security (TLS)
 - Basado en SSL3 pero con algunos pequeños cambios que lo hacen incompatible
 - Primer RFC publicado en 1999, RFC 2246 (TLS, versión 1)
 - Última versión, 1.3, RFC 8446 (agosto 2008)
 - Nota: Algunas funciones críticas para el rendimiento, como HTTP/2, requieren explícitamente el uso de TLS 1.2 o superior
- Por costumbre, se sigue utilizando el acrónimo SSL para referirse tanto a SSL como a TLS

TLS

- La motivación de Netscape al crear SSL fue garantizar la seguridad de las transacciones de comercio electrónico en la web.
- Requería
 - **Cifrado** para proteger los datos personales de los clientes
 - **Autenticación** y garantías de **integridad** para asegurar una transacción segura
- SSL se implementó en la capa de aplicación, directamente sobre TCP
 - Permite que distintos protocolos de aplicación (HTTP, correo electrónico, mensajería instantánea, entre otros) funcionaran sin cambios, a la vez que proporcionaban seguridad en la comunicación

Servicios esenciales de TLS

- Cifrado
 - Para ocultar información que se envía (confidencialidad)
- Autenticación
 - Para verificar la validez del material de identificación proporcionado
- Integridad
 - Para detectar posible manipulación y falsificación de mensajes
- Se puede optar por no utilizar todas las características, aceptando los riesgos que esto implica

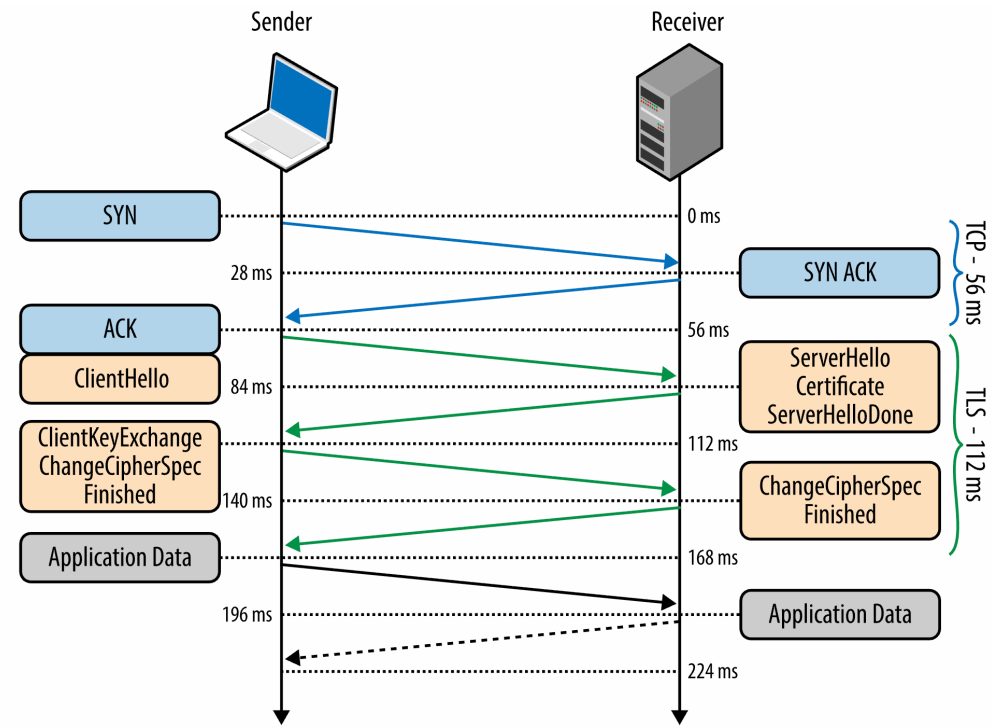
Requisitos de TLS

- Los peers deben acordar
 - Conjuntos de cifrado (**Cipher Suits**)
 - Claves para encriptar datos
- Requieren la negociación de la clave secreta, utilizando criptografía de clave pública (o de clave asimétrica)
- Ambos peers pueden **autenticar** su identidad
 - Esta verificación se basa en la **cadena de confianza** establecida
 - **Autoridades de certificación**
- TLS proporciona un mecanismo de enmarcado de mensajes y firma de cada mensaje con un Código de Autenticación de Mensaje (MAC), con el uso de algoritmos de hash (**integridad**)

TLS Handshake

- El intercambio de datos de la aplicación mediante TLS requiere la negociación previa de un túnel de cifrado.
- Cliente y servidor deben acordar:
 - La versión de TLS a utilizar
 - Elegir el conjunto de cifrado (**Cipher Suit**)
 - Verificar los certificados (opcionalmente, el servidor también podría solicitar certificado al cliente)
- Se realiza el handshake de TCP
- Cliente envía versión de TLS, lista de conjuntos de cifrado compatibles y otras opciones de TLS que se desee utilizar (Client Hello).
- Servidor selecciona versión de TLS, elige un conjunto de cifrado, adjunta su certificado y envía respuesta al cliente (Server Hello).
- Si el cliente está satisfecho con el certificado del servidor, inicia el intercambio de claves (RSA o Diffie- Hellman) para establecer la clave simétrica.
- Servidor procesa parámetros de intercambio de claves, comprueba la integridad del mensaje (MAC) y devuelve un mensaje Finished cifrado al cliente.
- Cliente decifra mensaje con la clave simétrica conocida, verifica la integridad (MAC) y si todo es correcto, se establece el túnel y comienza el envío de datos de la aplicación

Nota: otro aspecto que se negocia durante el handshake es el protocolo de aplicación a utilizar

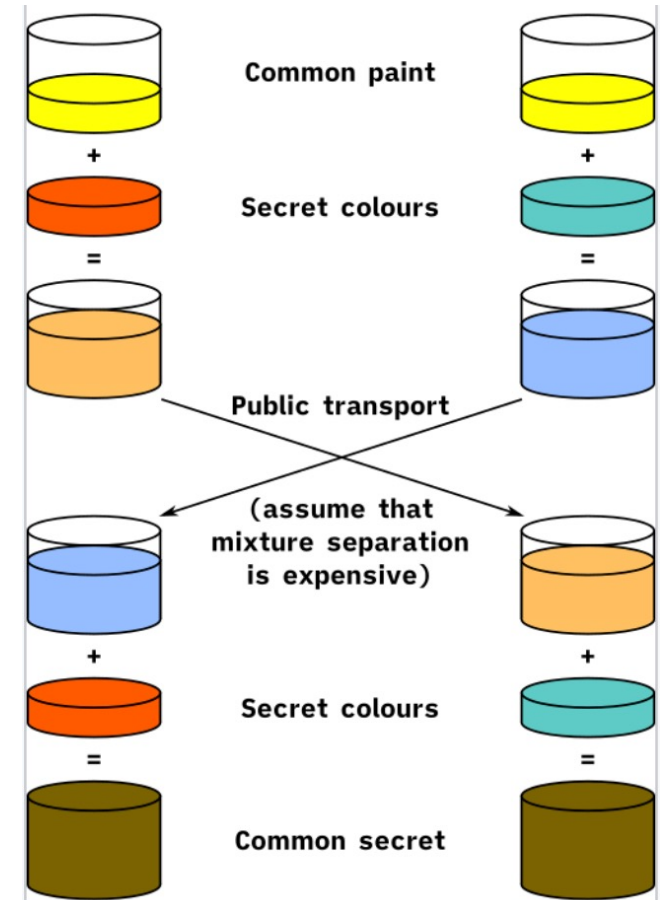


RSA

- Sistema criptográfico de clave pública o asimétrica, de Rivest, Shamir y Adleman.
- Mecanismo de **intercambio de claves** predominante en la mayoría de las implementaciones de TLS
 - Cliente genera una clave simétrica
 - Cliente cifra clave simétrica con la clave pública del servidor y la envía
 - Servidor utiliza su clave privada para descifrar clave simétrica recibida
- Esta clave simétrica negociada se utiliza para cifrar su sesión
- Vulnerabilidad:
 - RSA utiliza el mismo par de claves pública-privada para intercambio de claves y para autenticar al servidor
 - Si un atacante tuviera acceso a la clave privada del servidor, podría descifrar toda la sesión.

Diffie-Hellman

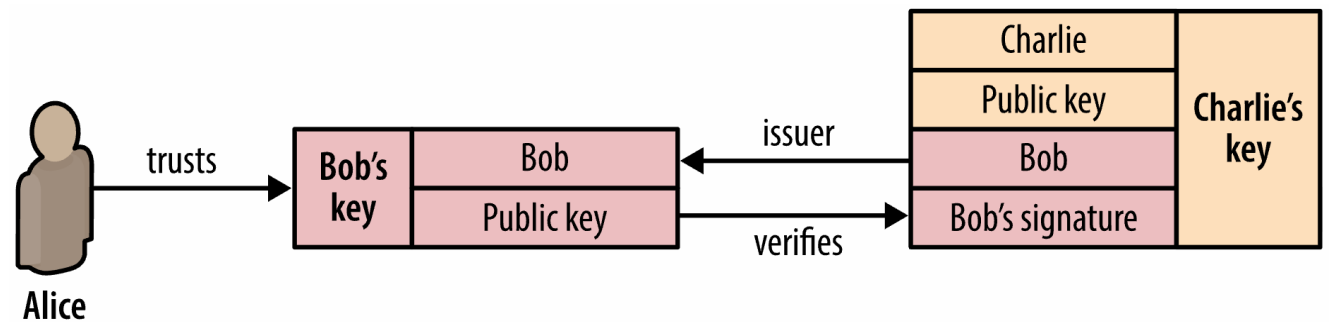
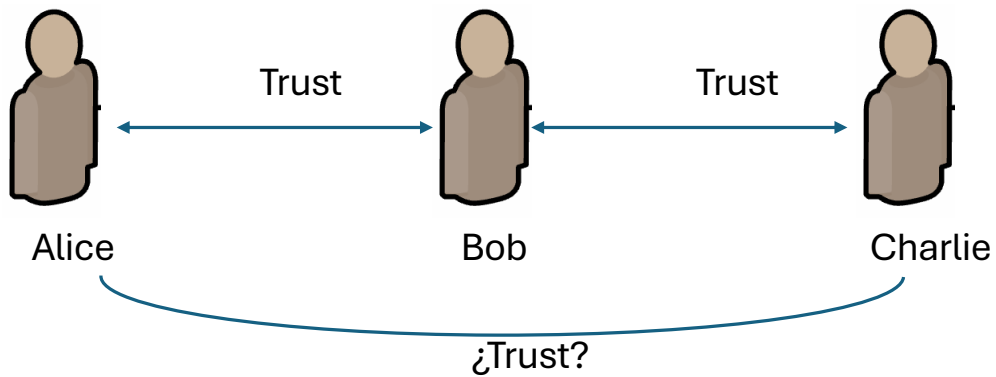
- Cliente y servidor pueden negociar el secreto compartido
- Analogía del funcionamiento (uso de colores)
 - Los peers intercambian un color inicial públicamente
 - Adicionalmente, los peers guardan un color secreto
 - Cada peer mezcla el color público con el color secreto, obteniendo una mezcla distinta cada uno.
 - La mezcla se intercambia públicamente
 - Cada peer combina dicha mezcla con su color secreto
 - El resultado es una mezcla final idéntica en cada peer
 - La mezcla final es la clave compartida
- En aplicaciones reales, los colores se reemplazan por números de cierta longitud
- Las claves compartidas son efímeras, es decir, se negocia una distinta por cada sesión.



Criptografía de clave pública VS Criptografía de clave simétrica

- La criptografía de clave pública se utiliza durante la configuración del túnel TLS.
 - Se autentican los certificados
 - Se ejecuta el algoritmo de intercambio de claves
- La criptografía de clave simétrica, utiliza dicha clave para toda la comunicación posterior entre cliente y servidor, dentro de la sesión.
- La criptografía de clave pública es más costosa computacionalmente.

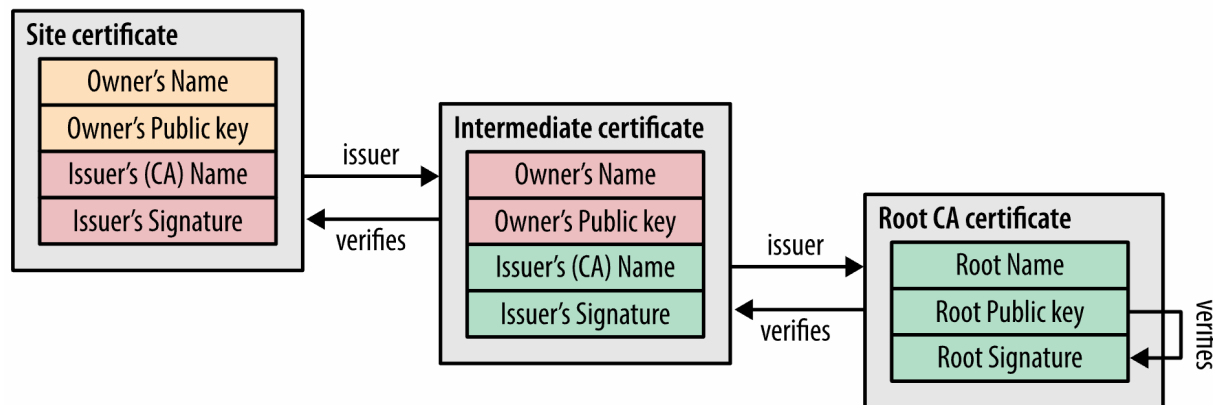
Cadena de confianza



Cadena de confianza Alice, Bob, Charlie

Autoridades de certificación

- Cuando se navega en la Web de forma segura, se establece una cadena de confianza.
- Debe haber una entidad en la que confíe el usuario y el navegador
 - Certificado especificado manualmente (lo obtiene el usuario y lo importa)
 - Autoridad Certificadora (CA)
 - Navegador y sistema operativo. El S.O. y la mayoría de los navegadores incluyen una lista de autoridades de certificación conocidas



Protocolo de registro TLS

Byte	+0	+1	+2	+3
0	Content type			
1..4	Version		Length	
5..n	Payload			
n..m	MAC			
m..p	Padding (block ciphers only)			

Para la entrega de datos a la aplicación:

- Se reciben los datos de la aplicación
- Los datos se dividen en bloques de máximo 16 KB
- A cada registro se le añade un Código de Autenticación de Mensaje (MAC) (hasta 32 bytes para TLS 1.2)
- Los datos de cada registro se cifran utilizando el algoritmo acordado
- Content Type. Identifica los diferentes tipos de mensajes (handshake, alerta – warning o fatal -, datos)

Todo este proceso lo gestiona la capa TLS y es transparente para la mayoría de las aplicaciones.

OpenVPN

- OpenVPN es una VPN SSL
- Implementa la extensión de red segura de capa 2 o 3 mediante el protocolo SSL/TLS
- Admite métodos de autenticación de cliente flexibles basados en certificados, tarjetas inteligentes y/o credenciales de nombre de usuario/contraseña
- Permite políticas de control de acceso específicas para usuarios o grupos mediante reglas de firewall aplicadas a la interfaz virtual de la VPN
- OpenVPN 2.0 permite que varios clientes se conecten a un único proceso servidor a través de un único puerto TCP o UDP

Configuración de OpenVPN



Modo de funcionamiento

- Modo Puente (Bridge)

- Túnel de capa 2
- El servidor actúa como un switch Ethernet para enlazar a los clientes con dispositivos de la red interna
- Utiliza interfaz llamada TAP (de Ethernet Terminal Access Point)
- El cliente obtiene una dirección del mismo rango de los equipos de la red interna
- Uso principal: acceso a los recursos de la red interna, como equipos compartidos, jugar en LAN, entre otros.
- Consume mucho ancho de banda
- No compatible con la mayoría de los dispositivos móviles
- Configuración más compleja

- Modo enrutamiento

- Túnel de capa 3
- Utiliza interfaz llamada TUN (de Túnel)
- El servidor crea una red distinta para los clientes VPN. Por defecto 10.8.0.0/24
- El servidor actúa como router entre la red de la VPN y la red local (NAT)
- Uso principal: acceso a internet seguro
- No hay paso de paquetes de broadcast
- Es el modo más utilizado

Requisitos

- Máquina virtual con Debian actualizado y red en modo puente

1) Configuración de Autoridad de Certificación

- Establecer una PKI (infraestructura de clave pública)
 - Requiere certificado independiente para servidor y cada cliente
 - Requiere un certificado y clave de Autoridad de Certificación (CA) maestra para firmar cada uno de los certificados de servidor y de clientes
 - Los relojes del servidor y del cliente deben estar aproximadamente sincronizados, de lo contrario, los certificados podrían no funcionar correctamente.
- Instalar paquete easy-rsa
- Crear directorio para certificados: ***make-cadir easy-rsa*** (en /etc/openvpn)
- Prepara infraestructura de clave pública
 - Desde easy-rsa/, ejecutar ***./easyrsa init-pki*** (crea directorio pki: /etc/openvpn/easy-rsa/pki)
- Construir certificado y clave de la Autoridad de Certificación (CA): ***./easyrsa build-ca***
 - IMPORTANTE: Recordar la frase solicitada, se requiere para firmar certificados posteriormente
 - Crea llave pública (certificado) en pki/ca.crt y clave privada en pki/private/ca.key

2) Crear certificado del Servidor

- Crear claves (pública y privada) del servidor:
 - ***./easymrsa gen-req servidor-feiuv nopass***
 - Genera clave privada en pki/private y clave pública en pki/reqs.
 - El parámetro *nopass* significa que la clave privada no estará protegida por una contraseña
- Firmar certificado (clave pública del servidor):
 - ***./easymrsa sign-req server servidor-feiuv***
 - Solicita contraseña que se dio a la entidad certificadora (pass phrase)
 - Genera certificado del servidor (clave pública certificada por la CA) en pki/issued

3) Crear certificado del Cliente

- Crear claves para cliente (desde openvpn/easy-rsa):
 - ***./easyrsa gen-req cliente1-feiuv nopass***
- Firmar requerimiento del cliente:
 - ***./easyrsa sign-req client cliente1-feiuv***